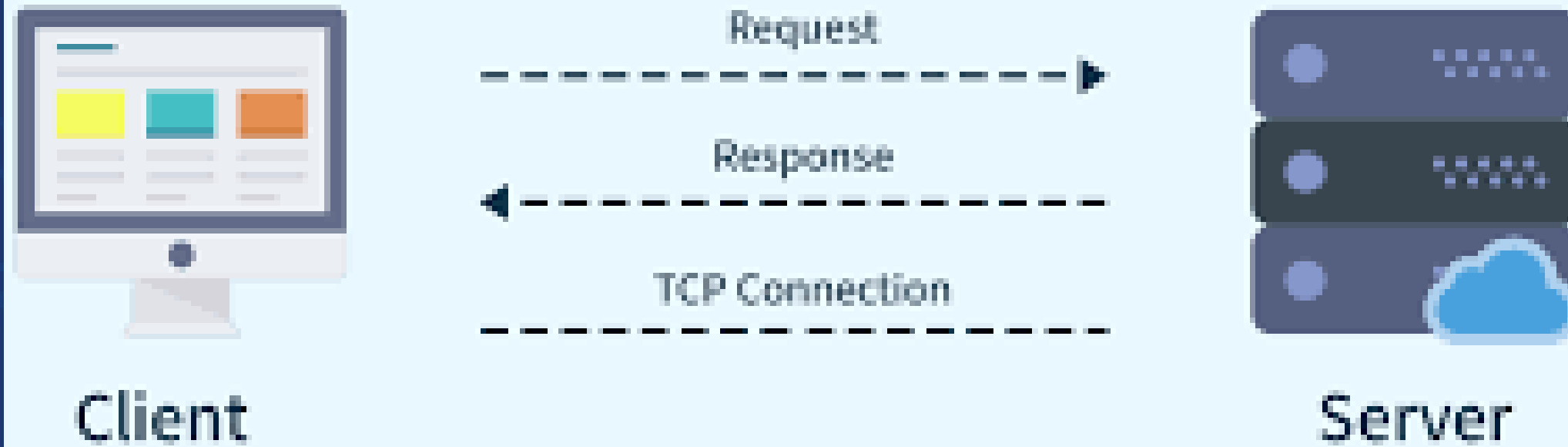


Kapıdaki Güvenlik Görevlisi: Tarayıcı vs. Sunucu

Web Güvenliğinde
Görünen ve
Görünmeyen Tehditler



HTTP Connection

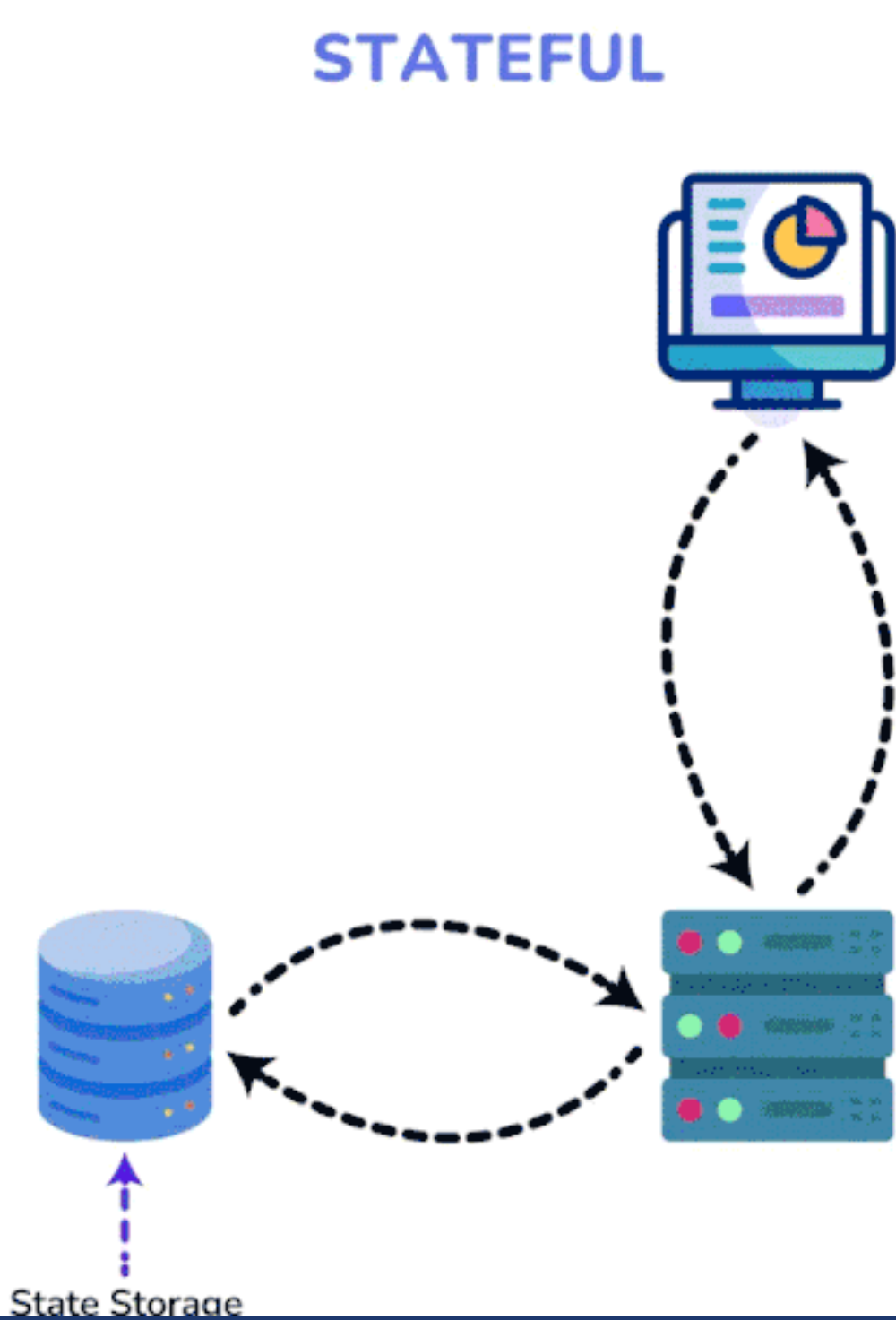


- Web uygulamalarının temel mekanizması:
istek-yanıt döngüsü
- Sunucu, tarayıcının arayüzünü değil ham HTTP isteğini dikkate alır.



Stateful vs Stateless

STATEFUL



STATELESS



HTTP STATELESS:

HAFIZASI OLMAYAN KİŞİ



HAFIZASI OLMAYAN KİŞİ

HTTP = Durumsuz Protokol
Her istek bağımsızdır
Sunucu geçmişini hatırlamaz

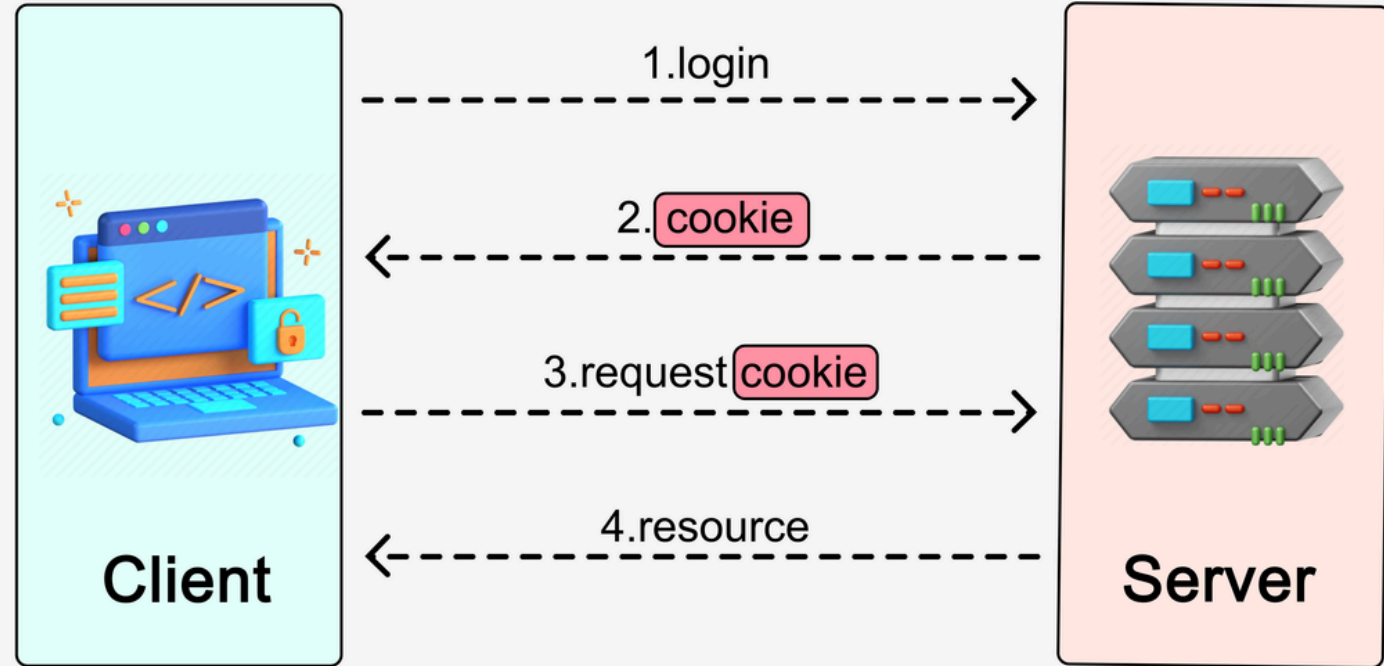
Çözüm: Cookie & Session → kullanıcıyı hatırlatır.

- Risk: Session hijacking → cookie çalınırsa şifreye gerek kalmaz.

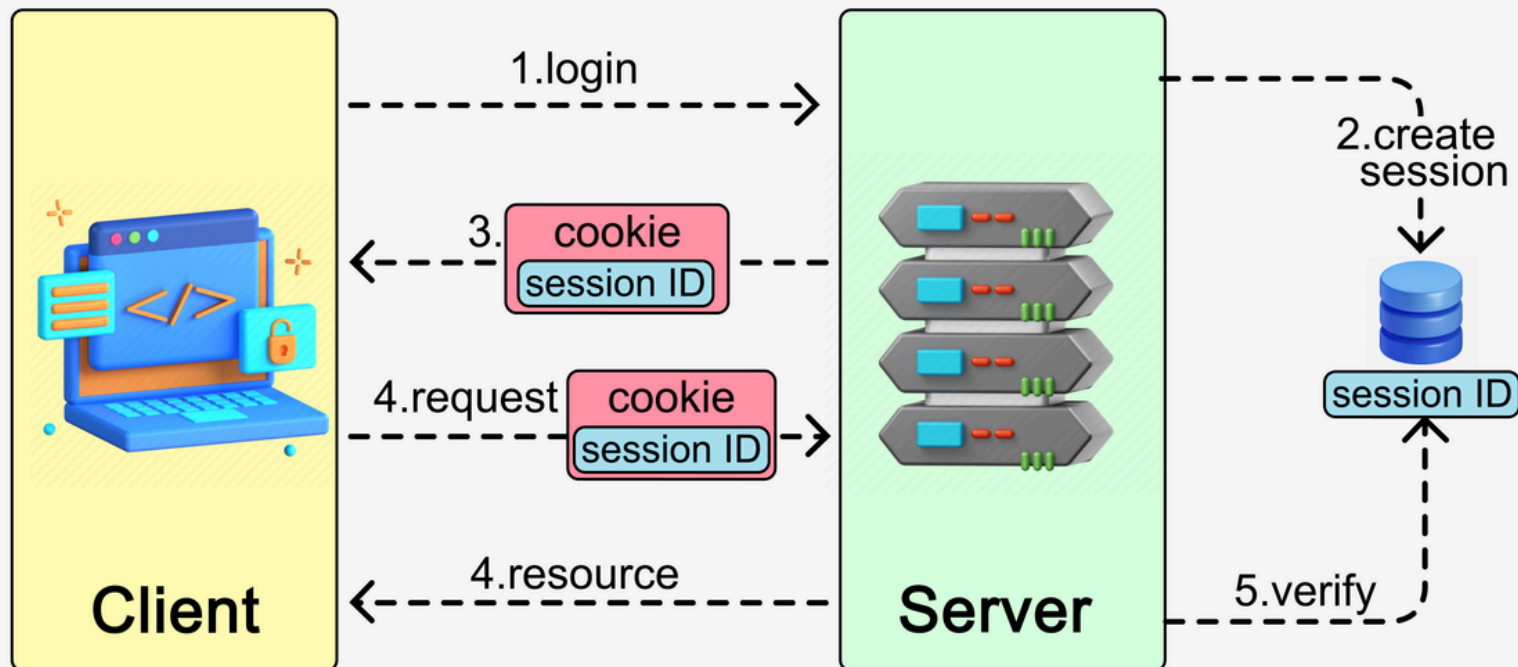
Cookies vs Sessions



Cookies

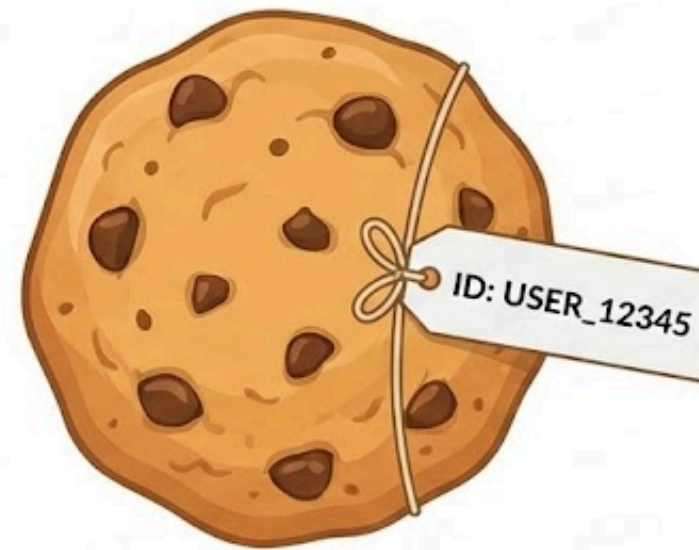


Sessions

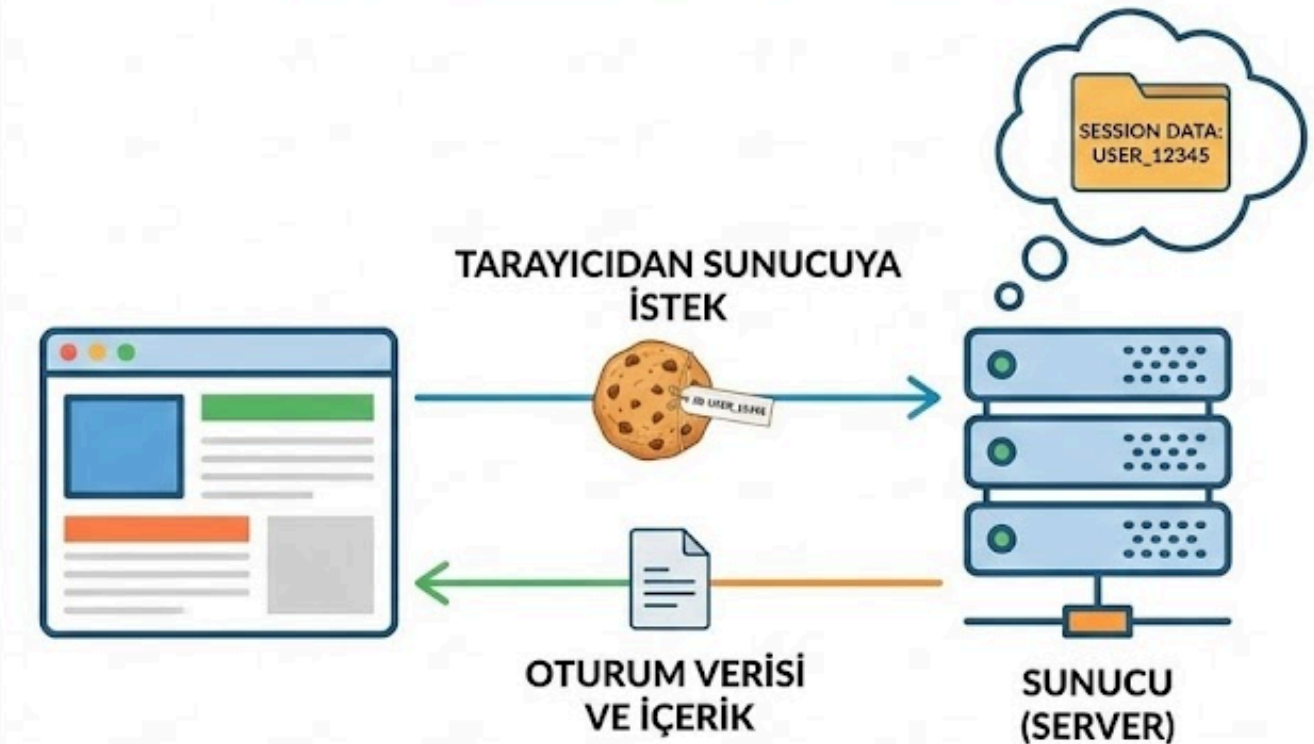


Peki login nasıl hatırlanıyor?
Session ID oluşturulur
Cookie ile tarayıcıya gönderilir

COOKIE SESSION DİYAGRAMI

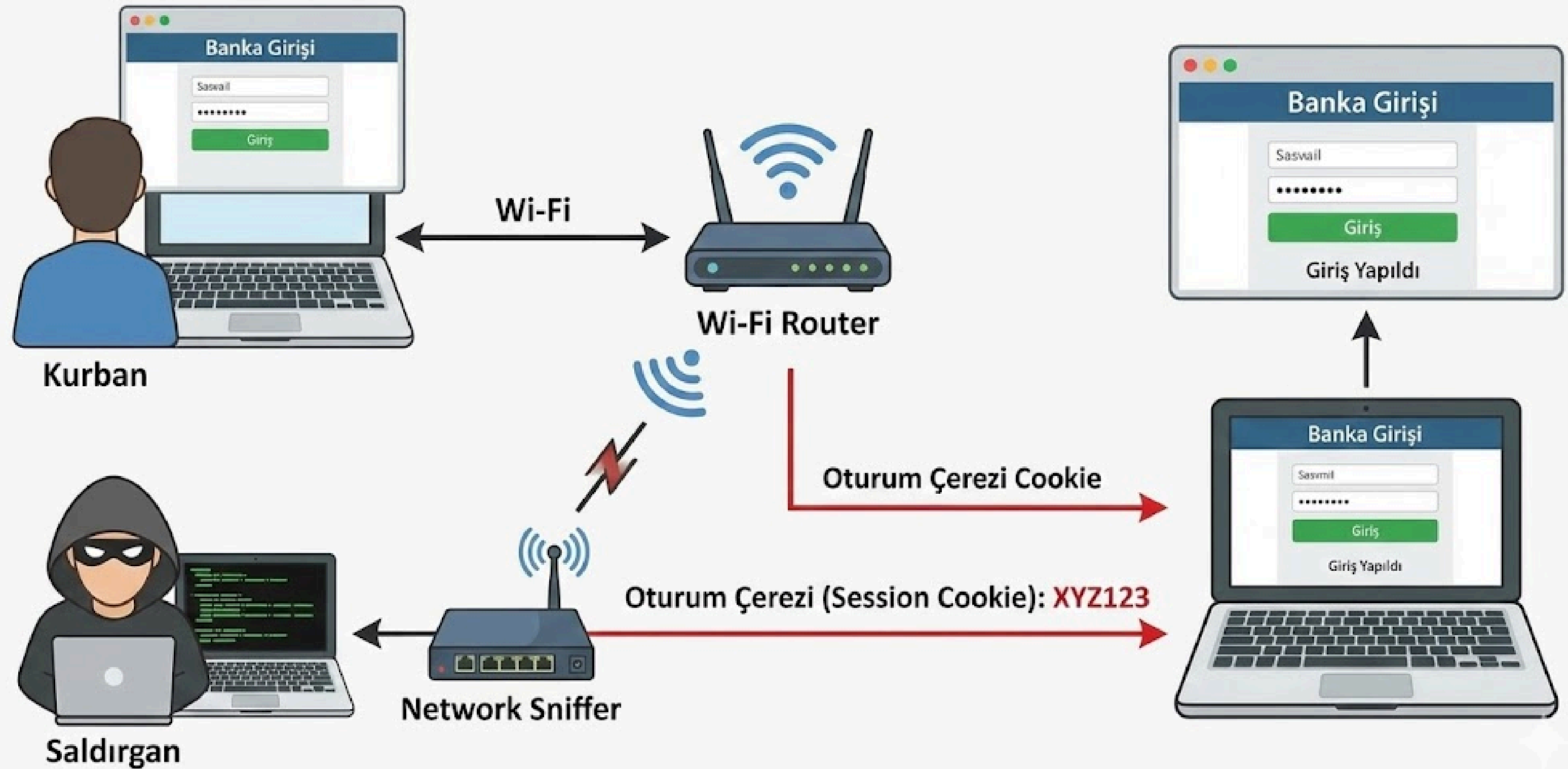


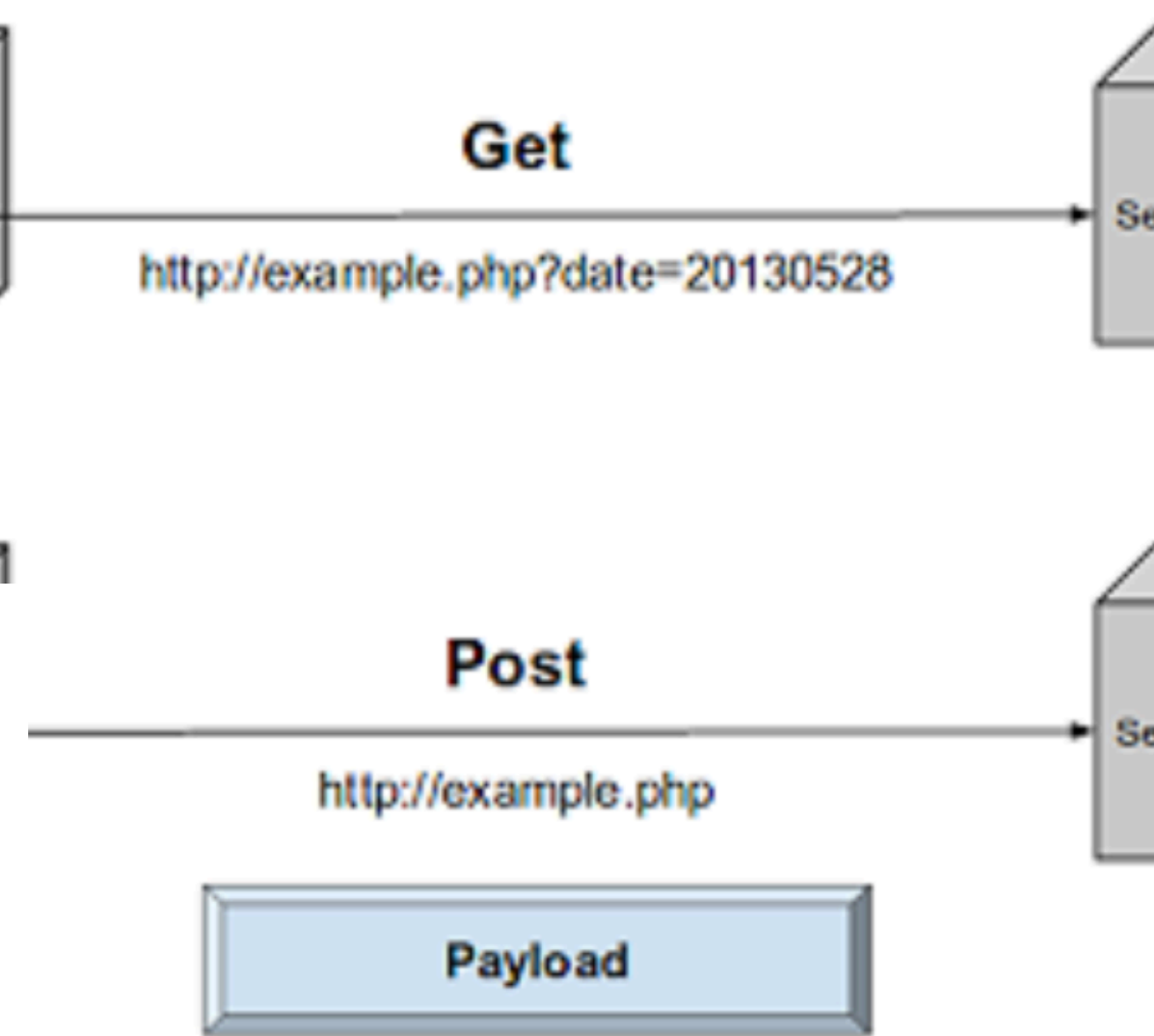
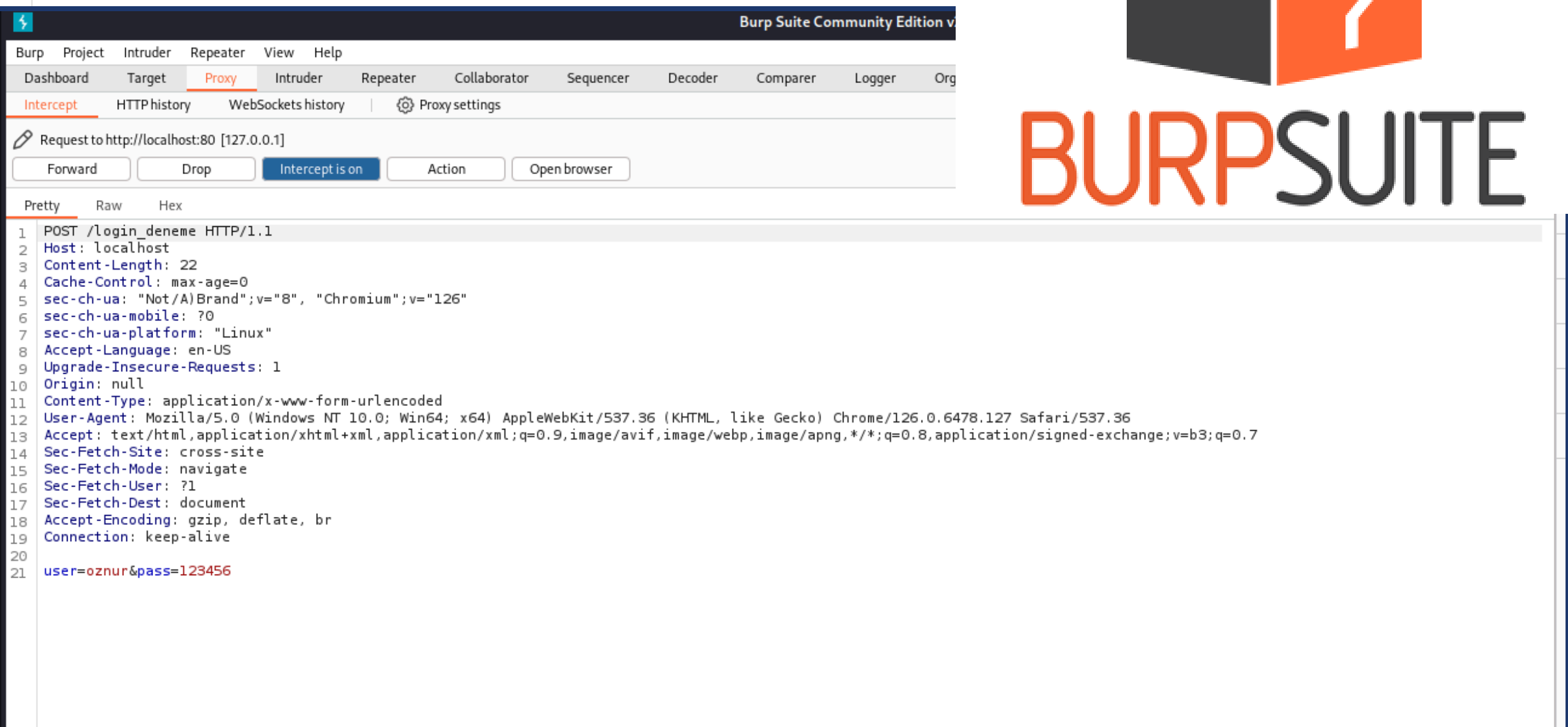
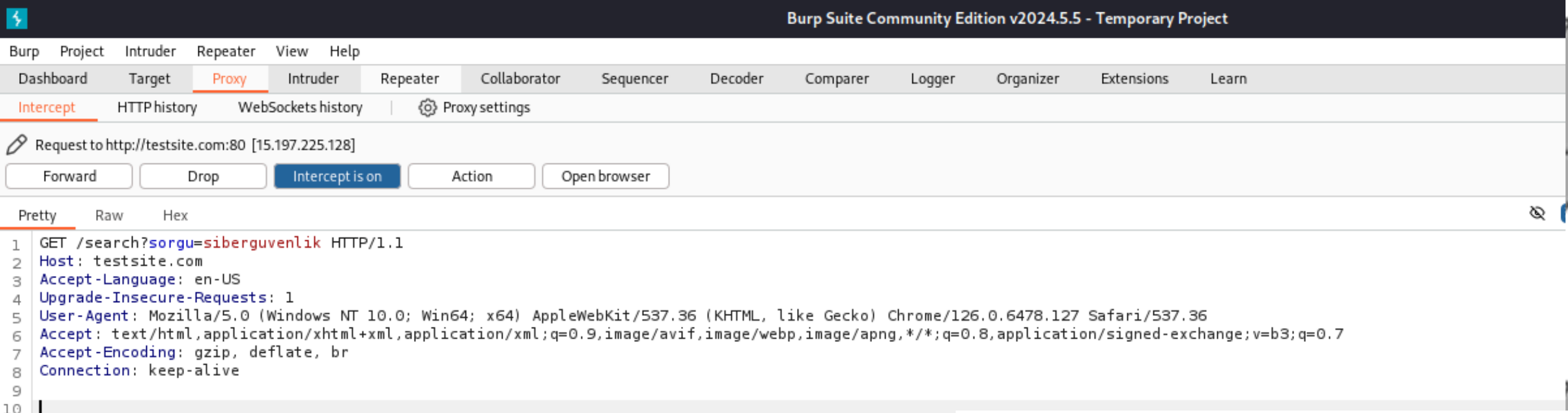
COOKIE & ID ETİKETİ



COOKIE SESSION DİYAGRAMI

SESSION HIJACKING





- GET → parametreler URL'de görünür.
- POST → veriler body içinde.
- Risk: Login formunda GET → şifreler loglarda ve geçmişte açık metin.

HTTP 404: SAYFA BULUNAMADI



İstek yapılan URL sunucuda mevcut değil. Sayfa kaldırılmış veya adresi yanlış yazılmış olabilir.

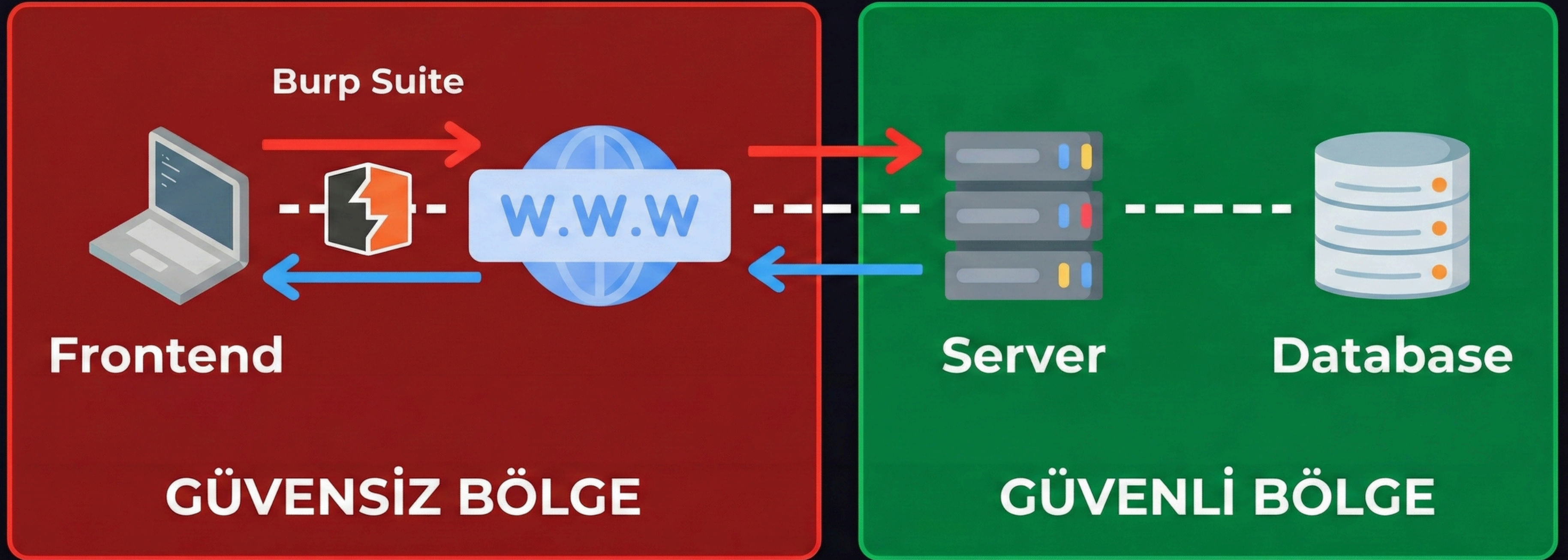
HTTP 403: ERİŞİM ENGELLENDİ



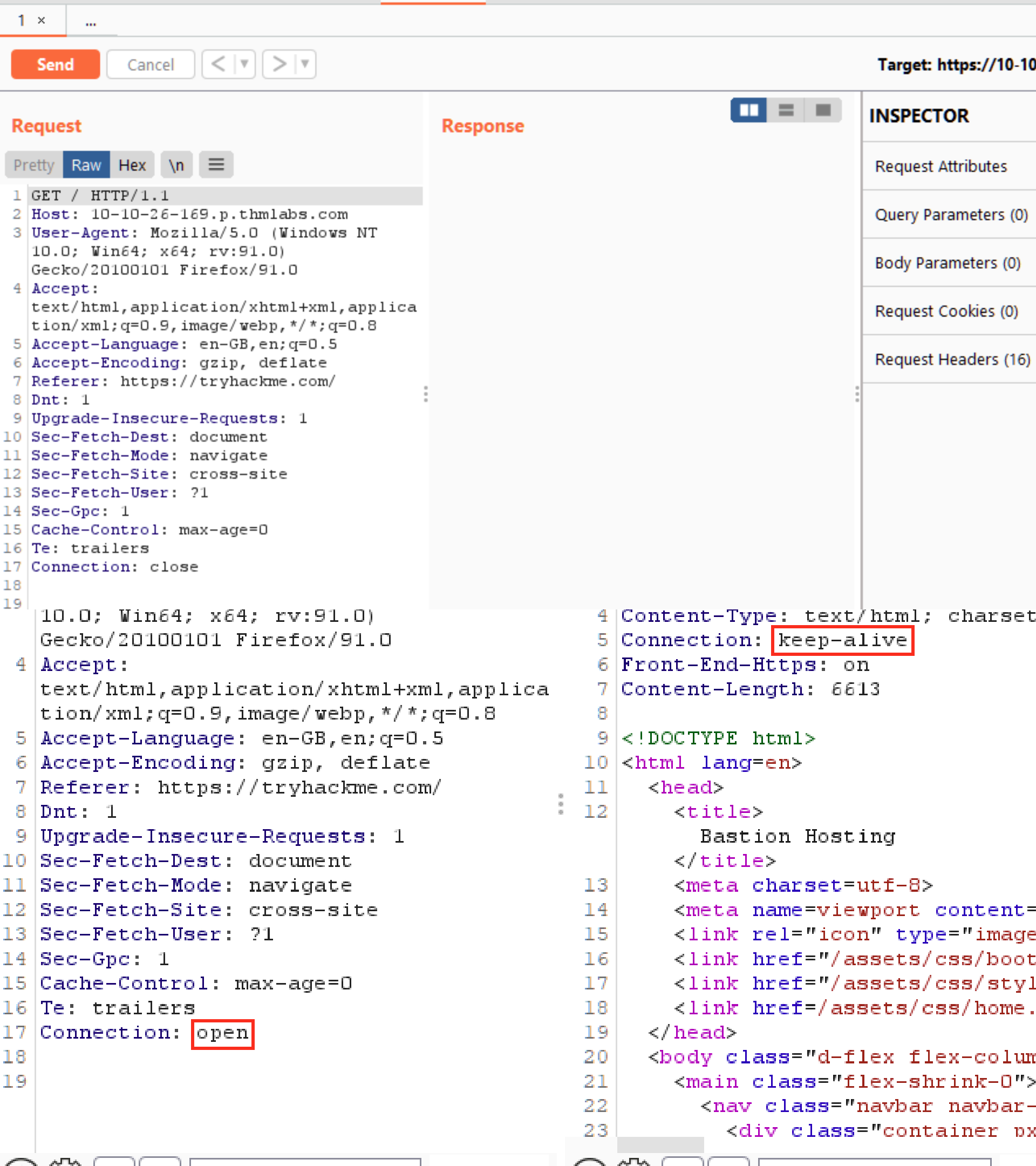
Sunucu isteği anladı ancak yerine getirmeyi reddediyor. Gerekli izinlere sahip değilsiniz.

- Yanlış şifreye 404 → kullanıcı adı yok.
- Yanlış şifreye 403 → kullanıcı adı var ama erişim yok.
 - 500 → sistem hatası, mimari bilgisi sızabilir.
 - Çözüm: Genel hata mesajları kullanmak.

Request-Response Cycle



Frontend kullanıcı deneyimi içindir, Backend güvenlik içindir.



JavaScript ≠ Güvenlik
Kullanıcı kontrolünde
Kolay bypass edilir

Repeater sayesinde
yakaladığımız isteğin üzerinde
istediğimiz değişikliği yapabilir
ve sonucu anında görebiliriz.



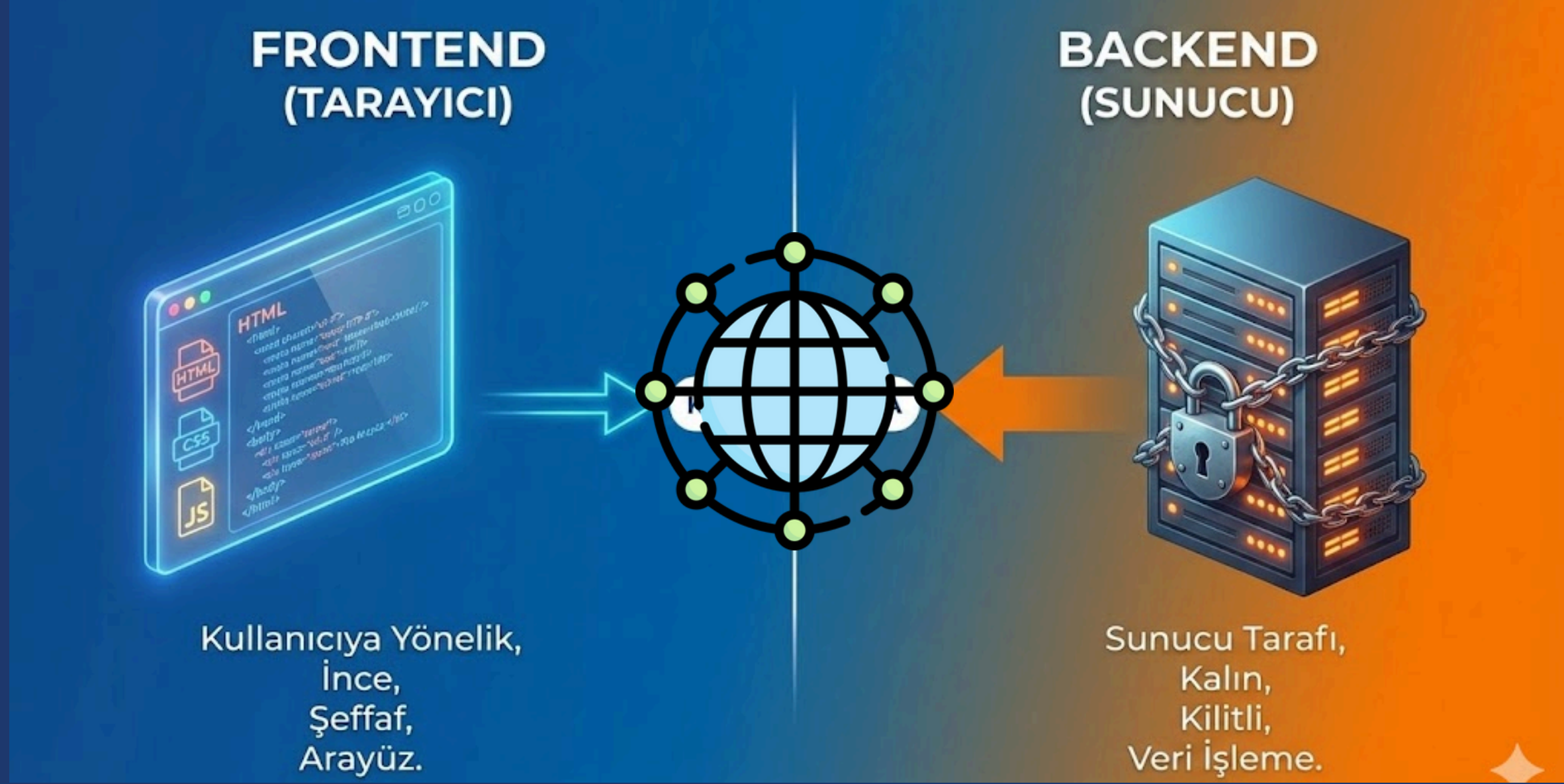
Asıl Güvenlik Backend'de Sağlanır



- ✓ Validation
- ✓ Sanitization
- ✓ Prepared Statements

Backend validation & sanitization zorunlu.

- SQL Injection önlemek için prepared statements.
- Gerçek güvenlik sunucuda sağlanır.



Frontend kullanıcı deneyimi içindir,
Backend güvenlik içindir.

Özetle, bir web uygulamasını güvenli yapan şey, kullanıcının ne gördüğü değil;
sunucunun gelen isteğe nasıl davrandığıdır.